今天繼續把 cis 的規則加進專案，但在加之前想先看有哪些東西不可能檢查得到

無法檢查到

- Root MFA、root access key、credential age，或是帳號資料
- 某些全域資源是否存在
- 有些要求涵蓋帳號內的所有資源
- preview 階段不會產生的資訊(arn、自動產生名稱等可能是 unknown)
- 部署後的實際行為

加入規則

- 在加入規則之後發現好像不管怎麼掃都不對，後來發現是因為 input 的欄位名稱跟資料來源都不一樣，所以需要改成 pulumi 的欄位名稱
- 並且其實有很多條規則都是看 cloudwatch 只是看的東西不一樣，所以我把他們統一合併起來



```
cmk_deletion_alarm_exists if {
    alarm := input.cloudwatch_alarms[_]
    filter := input.cloudwatch_log_metric_filters[_]
    contains(filter.filter_pattern, "DisableKey")
    contains(filter.filter_pattern, "ScheduleKeyDeletion")
    alarm.metric_name == filter.metric_name
}


s3_bucket_policy_changes_alarm_exists if {
    alarm := input.cloudwatch_alarms[_]
    filter := input.cloudwatch_log_metric_filters[_]
    contains(filter.filter_pattern, "PutBucketAcl")
    contains(filter.filter_pattern, "PutBucketPolicy")
    alarm.metric_name == filter.metric_name
}


config_changes_alarm_exists if {
    alarm := input.cloudwatch_alarms[_]
    filter := input.cloudwatch_log_metric_filters[_]
    contains(filter.filter_pattern, "PutConfigurationRecorder")
    contains(filter.filter_pattern, "StopConfigurationRecorder")
    alarm.metric_name == filter.metric_name
}


security_group_changes_alarm_exists if {
    alarm := input.cloudwatch_alarms[_]
    filter := input.cloudwatch_log_metric_filters[_]
    contains(filter.filter_pattern, "AuthorizeSecurityGroupIngress")
    contains(filter.filter_pattern, "AuthorizeSecurityGroupEgress")
    alarm.metric_name == filter.metric_name
}


nacl_changes_alarm_exists if {
    alarm := input.cloudwatch_alarms[_]
    filter := input.cloudwatch_log_metric_filters[_]
    contains(filter.filter_pattern, "CreateNetworkAcl")
    contains(filter.filter_pattern, "CreateNetworkAclEntry")
    alarm.metric_name == filter.metric_name
```

- 還有一些問題是因為這個檔案看起來是檢查一整個帳號的，但是我們只檢查 stack

控制項目	規則名稱	Rego 檢查條件
Root 帳號 access key	`root_account_keys`	`input.aws_account_summary.account_acc == 1`
CloudTrail S3 存取日誌	`s3_access_logging`	`bucket.is_cloudtrail_bucket == true` 且 `bucket.access_logging_enabled`
CloudTrail 多區域啟用	`cloudtrail_multi_region`	未啟用 `input.cloudtrail.multi_region_e`
未授權 API 呼叫監控	`alarm_unauthorized_api`	Filter Pattern 包含 `ERROR`、`Denied`，且 Al `metric_name` 相同

控制項目	規則名稱	Rego 檢查條件
NACL 管理連接埠限制	`nacl_admin_ports`	NACL 允許 `0.0.0.0/0` 存取 `22` 或 `3389`
`admin_port_in_rule`（SG 骨架）	`sg_admin_ports`	`rule.from_port <= 22 <= rule.to_port` 狀）
AWS Support IAM Role	`support_role`	Role 名稱包含 `support`，並掛載 `AWSSuppo`
Console 登入未使用 MFA	`alarm_console_without_mfa`	Filter Pattern 包含 `ConsoleLogin`、`MfaUse` Filter 的 `metric_name` 相同
Root 帳號使用	`alarm_root_usage`	Filter Pattern 包含 `root`，且 Alarm 與 Filte 相同
IAM Policy 變更	`alarm_iam_policy_changes`	Filter Pattern 包含 `DeleteGroupPolicy`、`DeleteRolePolicy`，且 Alarm 與 Filter 的
CloudTrail 設定變更	`alarm_cloudtrail_changes`	Filter Pattern 包含 `CreateTrail`、`UpdateT` 與 Filter 的 `metric_name` 相同
Console 驗證失敗	`alarm_console_auth_failures`	Filter Pattern 包含 `ConsoleLogin`、`Failed` Filter 的 `metric_name` 相同
KMS 金鑰停用或刪除	`alarm_cmk_deletion`	Filter Pattern 包含 `DisableKey`、`Schedule` Alarm 與 Filter 的 `metric_name` 相同
S3 Bucket Policy 變更	`alarm_s3_policy_changes`	Filter Pattern 包含 `PutBucketAcl`、`PutBuc` Alarm 與 Filter 的 `metric_name` 相同
AWS Config 設定變更	`alarm_config_changes`	Filter Pattern 包含 `PutConfigurationReco` `StopConfigurationRecorder`，且 Alarm 與 `metric_name` 相同
Security Group 變更	`alarm_security_group_changes`	Filter Pattern 包含 `AuthorizeSecurityGrou` `AuthorizeSecurityGroupEgress`，且 Aları `metric_name` 相同
Network ACL 變更	`alarm_nacl_changes`	Filter Pattern 包含 `CreateNetworkAcl`、`CreateNetworkAclEntry`，且 Alarm 與 Filt 相同
Network Gateway 變更	`alarm_gateway_changes`	Filter Pattern 包含 `CreateCustomerGateway` `DeleteCustomerGateway`，且 Alarm 與 Filt 相同

控制項目	規則名稱	Rego 檢查條件
Route Table 變更	`alarm_route_table_changes`	Filter Pattern 包含 `CreateRoute`、`CreateR` Alarm 與 Filter 的 `metric_name` 相同
VPC 變更	`alarm_vpc_changes`	Filter Pattern 包含 `CreateVpc`、`DeleteVpc` Filter 的 `metric_name` 相同
AWS Organizations 變更	`alarm_organizations_changes`	Filter Pattern 包含 `AcceptHandshake`、`Att` Alarm 與 Filter 的 `metric_name` 相同

規則	掃描前提
`s3_access_logging`	`aws:s3/bucket:Bucket` 或 `aws:s3/bucketV2:BucketV2`
`cloudtrail_multi_region`	`aws:cloudtrail/trail:Trail`
`alarm_*`（15 條）	`aws:cloudwatch/logMetricFilter:LogMetricFilter`
`support_role`	`aws:iam/role:Role`
`nacl_admin_ports`	`aws:ec2/networkAcl:NetworkAcl`
`sg_admin_ports`	`aws:ec2/securityGroup:SecurityGroup`
`imdsv2_required`	`aws:ec2/instance:Instance`、`aws:ec2/launchTemplate:LaunchTemplate` 或 `aws:ec2/spotInstanceRequest:SpotInstanceRequest`
`root_account_keys`	好像沒有辦法看

小結

把 cis 的規則加進專案的時候遇到三件事。

第一個是欄位名稱對不上。原本那份 rego 是寫給帳號掃描用的，輸入長得像 `aws_account_summary` 那種，我餵進去的是 pulumi preview 出來的資源，欄位名稱跟資料來源都不一樣，所以每條規則的取值都要改成 pulumi 的欄位名稱。

第二個是很多條規則其實是同一條。15 條 `alarm_*` 都在看 cloudwatch 的 `LogMetricFilter` 加上 metric_name 對得起來的 Alarm，差別只在 filter pattern 要比對哪些關鍵字，所以共通的部分合併起來，關鍵字用表帶進去。

第三個是帳號跟 stack 不是同一個範圍。原檔問的是這個帳號裡面有沒有一個 X，但我只看得到一個 stack 宣告了什麼，答不出有沒有。所以改成屬性判定，只看已經宣告出來的資源有沒有設對。`support_role` 改成名稱含 support 的 role 要掛 AWSSupportAccess，`cloudtrail_multi_region` 改成已宣告的 trail 要涵蓋所有 region 而且沒停用。

所以又補了一張掃描前提表，記錄每條規則要看到哪種 pulumi resource type 才會啟動，stack 裡根本沒有 cloudwatch 就不該因為沒有 alarm 被判不合規。`root_account_keys` 是唯一一條轉不過去的，帳號狀態沒有對應的 IaC 資源，只能永遠 n/a。

`s3_access_logging` 則是 preview 本身的限制，ARN 跟自動產生的名稱在 preview 階段還是 unknown，分不出哪個 bucket 是 CloudTrail 專用的，只好放寬成檢查所有 bucket。

參考資料

- CIS Amazon Web Services Foundations Benchmark
- CIS AWS Foundations Benchmark in Security Hub CSPM
- Policy Language | Open Policy Agent
- Write your own policy packs | Pulumi Docs(preview 階段的 unknown 值)
- LogMetricFilter | Pulumi AWS
- Filter and pattern syntax - Amazon CloudWatch Logs